

供应商准入、合同变更与临时采购协作规范

一、文档目的

本文档用于统一采购、法务、财务、信息安全和业务部门在供应商管理过程中的协作口径，明确供应商准入、合同变更、临时采购、访问控制、验收付款和例外登记等环节的职责边界。

本规范适用于供应商准入、合同签署、合同金额变更、临时采购、紧急替换供应商、验收付款、资料留存和例外登记等流程。所有审批动作均以公司采购系统、合同管理系统和财务付款系统中的记录为准。邮件、即时通讯或口头确认只能作为辅助材料，不能替代正式审批。

二、适用范围与基本原则

供应商管理并不是单纯比较报价。对于企业知识库、客户数据、内部工具或生产系统相关供应商，还必须关注安全、合规、服务连续性和可追溯性。业务部门可以提出采购需求，但不得绕过采购、法务和信息安全的检查要求。任何涉及客户数据、生产环境访问权限、核心系统凭证或长期外包服务的采购，都必须在正式合同签署前完成风险评估。

本规范将供应商和采购事项分为四类：标准采购、敏感采购、紧急采购和例外采购。不同类型对应不同审批人、材料清单、处理时限和回溯要求。

采购类型	典型场景	必须审批人	处理时限	最少材料	备注
标准采购	办公软件、普通云资源、低风险咨询服务	直属主管； 采购专员	3 个工作日	需求说明；报价单；预算编号	金额低且不接触客户数据时可走标准流程
敏感采购	接触客户数据、生产系统、日志平台或内部工单	直属主管； 采购经理； 信息安全负责人	5 个工作日	数据范围说明；安全评估表；供应商资质；访问权限清单	未完成安全评估不得签约
紧急采购	生产故障导致服务中断，需要临时替换供应商	业务负责人； 采购经理； 值班法务	4 小时内完成临时审批	故障说明；替换原因；临时服务边界；退出计划	事后 2 个工作日内补齐正式材料
例外采购	单一来源、未走比价、合同先执行后补签	部门负责人； 财务负责人； 法务负责人	2 个工作日内完成例外登记	例外说明；风险承诺；补偿控制；复盘计划	例外登记不等于风险豁免

三、角色职责

供应商准入需要多个角色协同。任何一个角色只完成自己负责的检查，并不代表整个流程已经结束。采购专员负责材料完整性，业务负责人负责需求真实性，法务负责合同条款，财务负责预算和付款条件，信息安全负责数据和系统访问风险。

角色	主要职责	不应承担的职责	必须输出
需求发起人	说明业务需求、使用范围、预计期限和验收标准	不得自行承诺付款、签署合同或开放生产权限	需求说明；验收口径
采购专员	检查报价、比价、供应商资质和流程完整性	不判断系统安全风险	比价记录；供应商准入记录
法务负责人	审查合同条款、违约责任、保密条款和争议解决方式	不替代业务判断供应商能力	合同审核意见
财务负责人	审核预算、付款节点、发票要求和成本归属	不审批技术访问权限	预算确认；付款条件说明
信息安全负责人	审查数据范围、系统权限、日志留存和退出机制	不承诺采购金额或付款时间	安全评估结论；权限边界说明
业务负责人	判断供应商是否满足业务连续性和交付目标	不跳过采购与法务流程	业务确认；上线风险说明

四、供应商准入分级

供应商准入分级用于决定是否需要增强评估。分级不是按金额单一判断，而是结合数据类型、系统权限、服务影响范围和合同期限综合确定。若多个条件同时满足，应按更高风险级别处理。

准入等级	触发条件	审批链路	复核周期	允许接触数据	退出要求
L1 低风险	金额低于 2 万元；不接触客户数据；不接入生产系统	直属主管；采购专员	每年复核一次	公开资料或非敏感样例数据	合同结束后归档即可
L2 一般风险	金额 2 万到 20 万；接触内部流程数据；不接触客户敏感信息	直属主管；采购经理；财务确认	每半年复核一次	内部非敏感数据；脱敏工单	结束后 5 个工作日内关闭账号
L3 较高风险	接触客户数据、业务日志、工单详情或内部知识库	业务负责人；采购经理；法务；信息安全	每季度复核一次	仅限授权范围内的脱敏或最小必要数据	结束后 3 个工作日内回收权限并确认日志留存

准入等级	触发条件	审批链路	复核周期	允许接触数据	退出要求
L4 高风险	可访问生产环境、核心数据库、客户敏感字段或长期驻场	部门负责人；法务负责人；财务负责人；信息安全负责人	每月复核一次	原则上不允许直接接触原始敏感数据	必须有退出清单、账号回收证明和复盘记录

五、合同金额与审批规则

合同金额变化经常影响审批链路。若合同金额、服务范围或供应商访问权限发生变化，不能只在原合同后补一个附件。系统内必须重新记录变更原因、变更范围、影响评估和审批人。

合同金额或变更类型	审批人	是否需要法务复核	是否需要财务复核	是否需要信息安全复核	完成时限
新合同低于 2 万元且不涉及敏感数据	直属主管；采购专员	否	否	否	3 个工作日
新合同 2 万到 20 万元	直属主管；采购经理	是	是	按数据范围判断	5 个工作日
新合同超过 20 万元	部门负责人；采购经理；财务负责人	是	是	按数据范围判断	7 个工作日
金额增加超过原合同 15%	部门负责人；财务负责人	是	是	若访问范围扩大则必须复核	5 个工作日
服务范围新增客户数据处理	业务负责人；信息安全负责人；法务负责人	是	按金额判断	是	5 个工作日
合同期限延长超过 6 个月	业务负责人；采购经理	是	是	L3/L4 供应商必须复核	5 个工作日
付款节点提前或预付款比例提高	财务负责人；部门负责人	按合同条款判断	是	否	3 个工作日

六、数据与系统访问控制

供应商访问内部系统时，应采用最小权限原则。账号不得共用，不得使用个人邮箱作为系统登录主体，不得把生产系统凭证通过即时通讯工具发送给供应商。供应商需要访问测试环境时，也必须说明访问目的、有效期和回收责任人。

访问对象	允许方式	禁止方式	有效期	回收责任人	日志要求
内部知识库	只读账号；按文档 ACL 授权	导出全量知识库；共享员工账号	最长 30 天	需求发起人	记录登录、查询和导出动作
工单系统	供应商专用账号；限制项目范围	查看无关客户工单；批量下载附件	最长 14 天	业务负责人	保留访问日志 180 天
测试环境	VPN + 临时账号；限定 IP	使用员工 VPN；绕过堡垒机	最长 7 天	技术 owner	记录命令审计和变更记录
生产环境	原则上不允许；确需访问需 L4 审批	直接提供 root、数据库账号或长期 token	单次最长 4 小时	信息安全负责人	必须开启操作审计和事后复盘
数据导出文件	加密链接；到期自动失效	个人网盘；私人聊天工具；明文邮件	最长 3 天	数据 owner	记录导出人、审批人、字段范围和接收确认

七、临时采购和紧急替换

紧急采购用于处理服务中断、供应商不可用或生产事故，不应用于规避正常流程。临时采购可以先行建立最小可用服务，但必须限定边界、保留记录，并在事后补齐正式审批。

紧急场景	可先执行动作	必须同步对象	事后补齐材料	最晚补齐时限	不允许动作
现有供应商系统故障导致客户服务中断	启用备用供应商的最低权限服务	业务负责人；采购经理；值班法务	故障说明；替换记录；服务边界；退出计划	2 个工作日	直接开放生产数据库
合同即将到期但续签未完成	延长原供应商临时服务周期	部门负责人；财务负责人	临时延期说明；续签计划；付款风险说明	3 个工作日	无审批继续扩大服务范围

紧急场景	可先执行动作	必须同步对象	事后补齐材料	最晚补齐时限	不允许动作
安全漏洞要求立即切换工具	暂停风险工具并启用已备案替代工具	信息安全负责人；技术 owner	漏洞说明；替代工具评估；影响范围	2 个工作日	使用未备案且无法审计的外部工具
供应商人员离职影响交付	要求供应商更换联系人并交接材料	采购经理；业务负责人	人员变更说明；交接清单；权限回收证明	5 个工作日	继续使用离职人员账号

八、验收、付款与资料归档

验收不是确认“供应商已经做了事”，而是确认交付物满足合同和业务目标。若验收材料不完整，财务不得安排付款。若交付内容涉及系统配置、脚本、数据清洗规则或知识库维护结果，必须保留可复现材料。

交付类型	验收材料	验收人	付款前置条件	归档位置	保留期限
咨询报告	报告正文；结论摘要；问题清单	业务负责人	报告已确认；无重大遗漏	合同系统附件	3 年
系统配置服务	配置清单；变更记录；回滚方案	技术 owner	变更已验收；监控无异常	变更平台；合同系统	3 年
数据处理服务	字段说明；脱敏方式；抽样检查结果	数据 owner；信息安全负责人	字段范围一致；无未授权字段	数据治理平台	5 年
知识库维护	更新条目；引用来源；审核记录	文档 owner	来源可追溯；无敏感泄露	知识库版本记录	3 年
驻场支持	工时记录；工作成果；权限回收证明	业务负责人；采购专员	权限已回收；交接完成	人员外包台账	3 年

九、版本变更检查项

制度版本发生变化时，不能只通知“文档已更新”。文档 owner 需要确认更新内容是否会影响审批链路、系统配置、历史合同和正在执行的采购。以下检查项用于确保版本变更可以被追溯。

检查项	是否必须	负责人	完成时限	证据材料	未完成影响
更新引用来源和回答口径	是	文档 owner	1 个工作日	新旧条款对照；FAQ 更新记录	问答系统可能继续引用旧口径
检查审批链路是否变化	是	采购经理	2 个工作日	审批节点清单；系统配置截图	审批流可能错配
检查历史合同是否受影响	是	法务负责人	5 个工作日	受影响合同列表；处理建议	历史合同执行风险无法识别
检查数据访问权限是否扩大	是	信息安全负责人	2 个工作日	ACL 变更记录；权限复核表	供应商可能获得过大权限
通知所有供应商	否	采购专员	按影响范围判断	通知记录	仅影响相关供应商时不需要全量通知
更新培训材料	否	业务负责人	10 个工作日	培训记录；更新说明	新流程理解不一致

十、例外登记字段

例外登记不是“允许违规”，而是为了记录为什么暂时无法按标准流程执行，以及如何补偿控制风险。未登记的例外不能作为事后付款或续约依据。

字段	填写要求	示例	是否可为空	审核人
例外原因	说明为什么不能走标准流程	现有供应商事故导致客户支持中断，需要临时替换	否	部门负责人
风险范围	描述涉及系统、数据、客户或合同范围	涉及工单系统附件下载，不涉及生产数据库	否	信息安全负责人
补偿控制	写明临时限制措施	仅开放只读账号；账号 48 小时后自动失效	否	信息安全负责人
退出计划	写明恢复标准流程的时间和责任人	两个工作日内完成正式比价和合同补签	否	采购经理
复盘结论	说明是否需要流程改进	紧急供应商名单不足，需新增备用供应商	是	业务负责人

十一、常见问答口径

问题	推荐回答	不应回答	引用依据
紧急采购是否可以先执行后审批	可以在最小边界内临时执行，但必须同步指定角色并在规定时限内补齐材料	紧急情况都可以先做后补	临时采购和紧急替换表
供应商能否直接访问生产数据库	原则上不允许；确需访问需 L4 审批并开启审计	找技术负责人要账号即可	数据与系统访问控制表
合同金额增加是否一定重新走审批	金额增加超过原合同 15% 时需要部门负责人和财务负责人审批	小幅增加不用审批	合同金额与审批规则表
制度变更后必须通知所有供应商吗	不一定，按影响范围判断；但必须更新引用来源、审批链路和权限复核	必须通知所有供应商	版本变更检查项表

十二、附则

本规范由采购管理部门牵头维护，法务、财务、信息安全和业务部门共同参与评审。制度更新后，文档 owner 应在一个工作日内完成版本记录，并通知受影响部门确认执行口径。

如本规范与公司合同管理制度、财务付款制度或数据安全制度存在冲突，应优先执行更高等级制度要求，并在例外登记中记录冲突原因、临时处理方式和后续修订计划。